

Healthcare Security Simulation

HIPAA Compliance Assessment Matrix

Simulated Environment: Metasploitable-Target (mock clinic system) | Monitoring Platform: Splunk-SIEM | Framework: 45 CFR §164.308–312 (HIPAA Security Rule)

Access Control — 45 CFR §164.312(a)

Control ID	Control Description	Evidence Reviewed	Status	Notes
164.312(a)(1)	Unique user identification for each workforce member	Local user accounts (msfadmin, root) reviewed on Metasploitable; no per-role clinic user accounts (front desk, nurse, billing) were provisioned in this environment	Gap	Simulated clinic system uses shared default credentials rather than individually assigned accounts, preventing accurate audit trail attribution to a specific workforce member
164.312(a)(2)(i)	Emergency access procedure to obtain ePHI during an emergency	No documented emergency access / break-glass procedure identified on the system	Gap	No mechanism observed for authorized emergency override of normal access restrictions
164.312(a)(2)(ii)	Automatic logoff after a predetermined period of inactivity	SSH and console sessions reviewed; no session timeout configuration found	Gap	Idle sessions remain open indefinitely, increasing risk of unauthorized access via an unattended terminal
164.312(a)(2)(iv)	Encryption/decryption of ePHI at rest and in transit	nmap scan identified Telnet (23), rsh/rlogin (512–514), and multiple services using weak or anonymous TLS (POODLE, Logjam, Anonymous DH — CVE-2014-3566, CVE-2015-4000)	Gap	Multiple in-transit protocols transmit data, including credentials, in cleartext; TLS-enabled services use deprecated, broken cipher suites

Data Handling — 45 CFR §164.502 / §164.530 (Minimum Necessary Standard)

Control ID	Control Description	Evidence Reviewed	Status	Notes
164.502(b)	Minimum necessary use, disclosure, and request of PHI	27 open TCP ports identified via nmap, including file-sharing (SMB/NetBIOS 139/445), NFS (2049), and remote execution (rexec/rlogin/rsh, 512–514) with no evident access restriction	Gap	Broad, unrestricted service exposure suggests systems and data are reachable well beyond what any single workforce role would need
164.530(c)	Administrative, technical, and physical safeguards to protect PHI privacy	Web application scan (Mutillidae/DVWA on port 80) identified SQL injection surface, CSRF vulnerabilities on login forms, and session cookies missing HttpOnly flag (Tomcat, port 8180)	Gap	Application-layer vulnerabilities could allow unauthorized disclosure or manipulation of PHI-equivalent data handled by the application
164.310(d)(2)(i)	Disposal — policies for final disposition of ePHI and hardware/media it resides on	No data retention, archival, or disposal policy artifacts found on the system	Gap	No evidence of a defined data lifecycle or secure deletion process for the simulated PHI records folder

Audit Controls — 45 CFR §164.312(b)

Control ID	Control Description	Evidence Reviewed	Status	Notes
164.312(b)	Hardware, software, and procedural mechanisms to record and examine activity in systems containing ePHI	Configured syslog forwarding from Metasploitable to Splunk-SIEM; captured and reviewed sudo/privileged command activity, SSH authentication successes and failures, and kernel/network interface events (288 events analyzed)	Partial	Logging and centralized review capability was successfully established and validated end-to-end (see SPL Search Log). However, the platform license constraints (Free tier) limit alerting, and no formal log review cadence or retention policy is defined for a production deployment
164.312(b)	Audit log content — who, what, when for privileged and access events	Captured msfadmin sudo escalation to root with full command line (e.g., config file edits, service restarts); captured 3 consecutive failed SSH login attempts for invalid users, each with source IP and timestamp	Compliant	Evidence directly supports individual accountability for privileged actions and demonstrates the system's capability to detect brute-force / unauthorized access attempts
164.312(b)	Vulnerability and risk-relevant event monitoring	nmap vulnerability scan (nmap --script vuln) identified 15+ high/critical	Gap	No automated detection or alerting mechanism exists to flag

		findings including a confirmed exploitable backdoor (CVE-2011-2523) and a trojaned service (UnrealIRCd)		exploitation attempts against these known vulnerabilities in real time
--	--	---	--	--

Legend: Compliant Partial Gap